Safe AI for Commercial Loan Underwriting

Reference Architecture & Compliance Overview: Underwriting Copilot

Executive Summary: Underwriting Copilot is an AI-assisted commercial loan preparation platform designed for SBA 7(a) and commercial lenders. It aims to reduce manual file assembly while enforcing deterministic rules, strict human-in-the-loop decisioning, sourced figures and tamper-evident auditing.

1. The Operational Challenge in Commercial Lending

Commercial loan underwriting traditionally demands hours of manual file preparation before credit risk assessment can even begin. Underwriters spend significant time reading tax returns, financial statements and bank records, manually keying figures into spreadsheets, verifying reconciliation, matching compliance criteria against complex government regulations (for example SBA SOP 50 10), and drafting credit memos.

This manual preparation phase is where human errors, such as missed document anomalies or mistyped figures, frequently occur. Underwriting Copilot automates file assembly so underwriters receive prepared loan files, with problems already flagged, ready for their review. The time saved is our hypothesis and has not been measured on real files.

2. Architectural Pillars of Safe AI

Unlike black-box generative AI models that produce unverified summaries or risk autonomous errors, Underwriting Copilot uses a rules-first, safety-first architecture built around five pillars:

> **Database-Level Human-in-the-Loop Enforcement:** The system cannot approve, decline or rank borrowers autonomously. The human-decision requirement is enforced by database rules, so errors in application code or external integrations cannot record a decision. Approving past an open critical or high exception also needs a written override.
>
> **Every Figure Sourced & Cited:** Extracted figures are linked directly to their source document, page number and quoted passage. Uncited facts are automatically rejected, allowing underwriters to verify numbers in seconds. Accepted means faithfully extracted, not verified true in the real world.
>
> **SBA SOP 50 10 Compliance Rules Engine:** Applies 11 SBA SOP 50 10 rules, each citing its section. Unresolved edge cases or discrepancies are surfaced directly to the human underwriter rather than silently skipped.
>
> **Prompt Injection & Document Shielding (“Documents Can’t Talk Back”):** Text within uploaded borrower documents is treated strictly as passive data, never as instructions to the model. Adversarial text or prompt-injection attempts designed to manipulate AI readers are flagged as critical exceptions and the facts from that document are held for a person.
>
> **Tamper-Evident Hash-Chained Audit Trail:** Every workflow state, extraction, rule evaluation and human action is recorded in an append-only, hash-chained ledger, giving examiners a record they can check for alteration.

3. End-to-End Underwriting Workflow Stages

Loan files move from initial intake to a prepared, reviewed and decided state through seven structured stages.

Stage	Workflow Step	Key System Operations & Safety Controls
1	Intake	Application intake with sensitive-identifier protection. The tax ID (EIN) is encrypted, and only the last four digits are exposed in the interface.
2	Documents	Malware scanning is required before any processing, and an upload is refused if the scanner cannot be reached. Name must match content; markup and active PDFs are refused. Documents are stored encrypted and scoped to the lender.
3	Extraction + Citations	Extraction of financial figures. Every fact is cited with source document, page and passage. Uncited facts are rejected.
4	Rules Evaluation	11 SBA SOP 50 10 compliance rules are evaluated automatically. Unknowns and exceptions are flagged for human review.
5	Memo Drafting	Draft credit memo generated with embedded source citations. Every figure is checked against its cited source, and the memo cannot contain approve or decline language.
6	Human Decision	The underwriter reviews, edits or adopts the memo and disposes each exception. Only underwriters can approve, decline or return files; approving past an open critical or high exception needs a written override, and a decided case is final.
7	Servicing Handoff and Audit	The final decision is recorded in the append-only ledger and queued, through a signed and retried outbox, to the servicing system. The servicing system is a mock adapter today.

4. Security, Isolation & Auditability

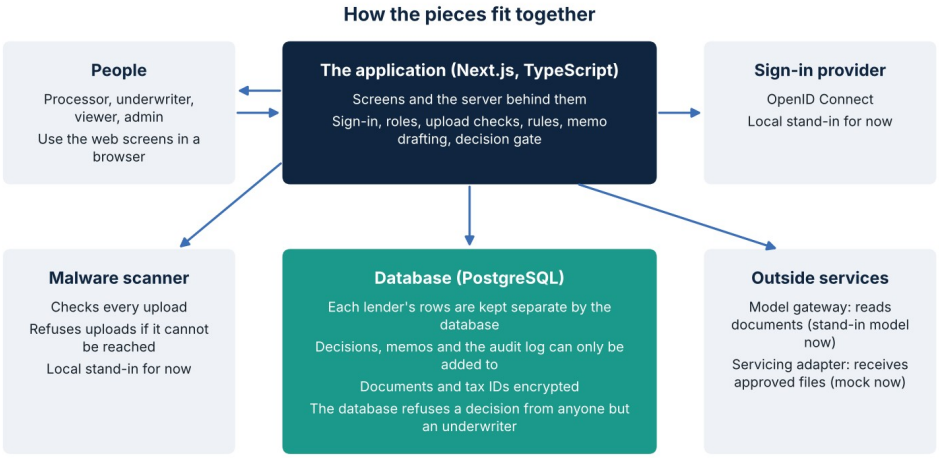
> **Multi-Tenant Isolation:** Tenant separation is enforced at the database layer rather than purely in application code, so an application bug cannot read across lenders. Tests that attempt cross-lender reads confirm they are denied.
>
> **Tamper-Evident Audit Ledger:** Instead of basic event logging, Underwriting Copilot uses a hash-chained, append-only ledger. An examiner can run the chain check to see whether past decisions, rules or document versions were altered. Whether a given examiner accepts it as evidence is for the lender and the examiner to decide.
>
> **Standard Technology Stack:** Built on standard, well-supported infrastructure (TypeScript, Next.js, PostgreSQL) without exotic dependencies, which should make review by internal risk and IT teams straightforward. The one component that is not deterministic is the AI model, which sits behind a single gateway and whose answers are checked against the source text.
>
> **Sign-in and roles:** OpenID Connect through the lender's own identity provider, four roles (processor, underwriter, viewer, admin), and sessions that can be ended at once.

5. Workflow and architecture diagrams

The workflow as a diagram. The audit record runs through every stage and is drawn as its own box (8). Stage 6 is the only place a decision is made.



How the pieces fit together. A web application is what people use. A database holds the data and enforces the most important rules itself. A malware scanner checks uploads. Outside services read documents and receive approved files. Items marked as stand-in are not real yet.



6. What we have measured, and the standards we map to

Item	Result	How to read it
Automated tests	454 pass, including real-database tests	Measured
Browser walkthrough of the whole workflow	40 of 40 steps pass with four roles and three files; also runs in the automated build on GitHub	Measured, synthetic data
Extraction on 120 synthetic packets (4,030 fields)	87.8% accepted and correct; none falsely accepted; 8.4% not extracted (scans, no OCR)	Measured with a stand-in model that reads printed labels
Planted problems	Caught in every packet of every class; two classes also over-flagged	Measured
OWASP ASVS 5.0.0, levels 1 and 2	253 requirements: 108 met, 40 partial, 1 not met, 41 deferred, 62 not applicable, 1 not assessed	Our own assessment, evidence cited
NIST AI RMF	72 subcategories: 9 addressed, 40 partial, 22 gaps, 1 not applicable	Our own assessment

7. What this does not do yet

> No real documents or lenders have been tested, so accuracy on real paperwork is unknown. A stand-in model is used, and scanned or image-only documents cannot be read yet.
>
> No time saving has been measured. A timed comparison with two underwriters is planned.
>
> Several checks are not built: eligibility, collateral, tax transcripts, personal financial statements, credit reports and global cash flow. Debt service uses only the new loan and a placeholder rate.
>
> Nothing is deployed, and no identity provider or hosting has been chosen.
>
> No outside penetration test, SOC 2 report or lender vendor review exists. Items for legal and compliance review are listed separately. Nothing in this document is legal advice.

8. Summary

Underwriting Copilot is designed so that speed never costs control. It prepares the file, sources every figure and applies the SBA rules, while the decision, the override and the record all stay with people and are enforced by the database.

Key takeaways.

> Efficiency without a black box: every figure links to its page and passage.
>
> Mandatory human decision: software cannot approve, decline or rank, and the database refuses it.
>
> Proactive defenses: malware scanning, documents treated as data, and separated lender data.
>
> Provable auditability: an append-only, hash-chained record of every action.
>
> Honest limits: synthetic data only; real-world accuracy and time savings are still to be measured.